Bounding the Harms of AI Agents: What Must Not Break

Recommendations and safeguards required to protect critical systems from AI agents

David J. Carlson, with Claude as contributor · 23 October 2026

Concern about AI is widespread, and much of it is about a future that may or may not arrive. This paper is about the present: measures that can and should be taken now to contain harms that AI systems and agents can already cause, or soon will. Most of what it recommends extends protections that already exist. Controls on chemical, biological, radiological and nuclear materials have been in place for decades, and banks, card networks and other operators of critical systems already run extensive defenses against people acting in bad faith. Those defenses were built for human adversaries. They now need to hold against agents that can act like millions of coordinated people, at machine speed and at almost no cost. A superintelligent, hostile AI may become possible one day, but whether and when is uncertain. What agents can do now, and what they will soon be able to do, is not uncertain, and much of it can be bounded today. Many of the same safeguards would also make harm by people acting in bad faith harder, a benefit that does not depend on how AI develops.

This paper provides:

- summaries for policymakers, for businesses and government agencies that agents can reach, and for operators of critical systems (Sections 1 to 3)
- a floor of three tiers of irreversible harm that must be prevented whatever else a society decides: catastrophic harm to humanity, serious disruption of society's core functions, and serious injury or significant financial loss to individuals (Section 4)
- why current laws do not reach uncontrolled agents, and where leverage over AI agents still remains (Sections 5 to 7)
- six functions that safeguards perform: bound, attribute, dissipate, detect, contain, and verify and bound (Section 8)
- fifteen safeguards for operators of critical systems, applied at the point of effect, where an agent's action enters a system and takes effect (Appendix A)
- who should bear each obligation, drawing on how payment rules, product liability and insurance already allocate loss, and a safe harbor for operators that run the safeguards (Section 9)
- the costs and risks of the safeguards themselves, since no control is free, and a test any safeguard should pass (Section 10)
- what lies above the floor and is left for each society to decide (Section 11)
- recommendations, mostly for policymakers and regulators, to ensure the safeguards are adopted, monitored and shown to work (Section 12)

Contents

Contents 2
List of Tables 3
1 Summary for policymakers 4
2 Summary for businesses and government agencies 6
3 Summary for operators of critical systems 7
4 The floor: three tiers of harm 8
4.1 Definitions 8
4.2 Why the floor is drawn at irreversibility 9
4.3 Why these three tiers 9
4.4 Two principles fix the floor's character 10
4.5 Protecting the safeguards 10
4.6 What the floor does not promise 11
5 Uncontrolled agents 12
5.1 Who holds the controls 12
5.2 Three populations 12
5.3 The unattended case 13
6 Where current AI governance instruments stop 14
7 Where leverage over AI agents remains 16
7.1 Leverage by party 16
7.2 What email shows 17
7.3 Known gaps in the internet's plumbing 17
8 Safeguards by function 19
8.1 Bound: scale checks to what cannot be undone (P1, P2, P3) 19
8.2 Attribute: tie agents to someone accountable (P4, P6, P9) 19
8.3 Dissipate: make cheap harm at scale expensive (P5) 19
8.4 Detect: see what no single operator can (P10, P11) 19
8.5 Contain persistence: keep agents from outliving their owners (P7, P8, P12) 20
8.6 Verify and bound: identity is not trust (P13, P14, P15) 20
9 Who is responsible for the safeguards and the losses 23
10 Safeguard costs and risks 25
10.1 Identity can become surveillance (P4, P9, P13) 25
10.2 Compliance can entrench incumbents (P4, P6, P11) 25
10.3 Friction falls hardest on those with least access (P1, P2, P13) 25
10.4 Detection is sometimes wrong (P5, P10, P12) 26
10.5 The safeguards become targets (P6, P8, P10) 26
10.6 Controls can reach open research (P7, P8) 26
10.7 A test for every safeguard 27
11 Above the floor: what society decides 28
12 Recommendations and open questions 29
Appendix A: Point-of-effect safeguards 31
A.1 The fifteen safeguards 31
A.2 Before adopting or adding a safeguard 33
Appendix B: Glossary 34

Appendix C: Sources 37
Appendix D: Key lists at a glance 39
D.1 Tiers of harm that must not occur (Table 1) 39
D.2 Leverage over AI agents, by party (Table 3) 39
D.3 Known gaps in the internet's plumbing (Table 4) 39
D.4 Safeguards by function (Section 8) 39
D.5 Listing a critical system's interfaces (Section 8.6) 39
D.6 Point-of-effect safeguards (Table A1) 39
D.7 Safeguard costs and risks (Section 10) 40
D.8 Recommendations (Section 12) 40
D.9 Open questions (Section 12) 40

List of Tables

Table 1. The three tiers of harm that must not occur 8
Table 2. Current AI governance instruments: whom they oblige and where they stop 14
Table 3. Where leverage over AI agents remains, by party 16
Table 4. Known gaps in the internet's plumbing 18
Table A1. Point-of-effect safeguards P1 to P15 31

1 Summary for policymakers

AI agents can help people, teams and societies move faster, drawing on more of humanity's knowledge than any person holds, at the speed of computers. Like most technologies, from fire to the computer, they can also cause harm, and they are improving quickly. This paper is about bounding the harm AI agents can do, including agents that no one controls.

Most rules for AI agents assume someone runs each agent and wants it controlled. That assumption is failing. Models whose weights are published can be copied, run on hardware their developer never sees, and wrapped in agent software by anyone. As models shrink and phone chips gain processors built for AI, an agent no longer needs a data center, or even a desktop computer: it can run on a phone. For a growing share of agents, no party both holds the controls and intends to use them. This paper calls these **uncontrolled agents**. Whoever runs one may be careless, hostile or impossible to find, and no one else may be able to stop it. Agents on models under served access, reached only through the developer's request path, can also do harm, but the developer sees every request and can cut off misuse. Uncontrolled agents have no such check, and they are this paper's main concern, all the more as their number grows.

This matters because an agent may do more than answer; it may act. It may work with a person's credentials, on their behalf: sending messages, moving money and changing records. Models learn from vast amounts of human writing, and with this knowledge they absorb human ways of deceiving, manipulating and cutting corners. How much of that knowledge is trained out depends on who trains the model, and not every developer is careful or well intentioned. Worse, anyone holding a model's weights can retrain it to strip out that training. An agent can therefore do what a careless or hostile person could do, at machine speed and scale, with no one watching. For one person, that can mean savings emptied; across millions of agents, a city's services halted, and at the extreme, harm to humanity.

This paper does not try to decide how much disruption from AI is too much. That is for each society. It defines a floor that must hold whatever a society decides, because harm below it cannot be undone and so cannot be decided about afterward. The floor is three tiers of harm that must not occur (Section 4):

1. **Catastrophic harm to humanity:** harm that ends or permanently diminishes human life or civilization, or kills or injures very large numbers of people at once.
2. **Serious disruption of society's core functions:** critical infrastructure, payment and financial systems, emergency services, or the processes by which a society makes and revises its collective decisions.
3. **Serious injury or significant financial loss to individuals:** serious or lasting injury to a person's life or health, or a loss through fraud or theft, not recovered or repaid, greater than the person can absorb without lasting harm to their livelihood or ability to meet ordinary needs.

The floor cannot rest on the cooperation of whoever runs an agent, since the harms that matter most come from those who will not cooperate. It has to be enforced where an agent's actions take effect: at the bank that moves the money, the utility whose controls open a valve, the emergency service that dispatches help. The paper calls these **critical systems**. The place where an agent's action enters one is the **point of effect**. The parties that operate them can enforce, they already run most of the relevant

machinery, and they remain reachable by law when the agent's owner is not. Hosts and networks that carry agents are not critical systems, but they hold leverage of their own (Section 7).

The paper sets out fifteen safeguards at points of effect for operators of critical systems, numbered P1 to P15 (Appendix A). Their aim is to raise the cost of harm, bound the damage and keep harm traceable, not to make harm impossible. The paper also recommends to policymakers, regulators and others the laws, regulations and rules needed to ensure the safeguards are applied (Section 12).

Three limits apply. The safeguards act on what an agent does on a critical system, not on the agent itself, so they cannot stop a determined actor from running a model on its own hardware, or catch harm that never passes through a critical system. Controls have costs of their own, including to privacy and open research. And harms from agents working as designed, such as effects on work or on public information, are real but sit above the floor, where each society decides.

2 Summary for businesses and government agencies

This summary is for anyone who runs a system that agents can reach, which today means almost every business or government agency. Agents can now place orders, open accounts and submit requests at machine speed, and some will be careless or hostile, so these systems will receive requests no person would make. Most organizations need only a few basic safeguards: to recognize agents, limit what they can do and keep records. These protect the organization when a dispute or liability question arises, and they give the critical system downstream what it needs to refuse a harmful request. Operators of critical systems carry more, set out in Section 3. References such as (P3) point to the fifteen safeguards, P1 to P15 (P for point of effect), listed in Table A1 (Appendix A), which gives each one's purpose, where it must operate and who must run it. They are distinct from the numbered recommendations in Section 12.

Most businesses and agencies that expose an interface, from a shop's point-of-sale system to an online booking page or a city's permit portal, are not the last point of control: if they are fooled, a bank, processor or other critical system downstream can still refuse. Existing liability rules, and for agencies the duties they already carry, give them reasons to be careful, and those rules will reach transactions agents start. Agents change the odds, not the rules, and liability tends to settle on whoever is least prepared. When U.S. card networks moved to chip cards in 2015, liability for counterfeit fraud shifted to "the party with the lesser technology" (Square). Building for agents now is how to stay on the right side of the next such shift.

- **Expect agents.** Assume that some of your customers are agents, and that some requests come from agents, and design checkout, account and support flows so that an agent's request can be recognized and, where it matters, handled differently from a person's.
- **Make requests safe to repeat, and limit rate and spend** (P3, P5), more tightly for requesters that do not declare themselves.
- **Accept declared agent identity where it is offered, and pass it on** (P4, P13) to the payment processor or other critical system downstream, so it can apply its own controls.
- **Keep logs** that show what was requested, by whom and on whose authority (P9). When a dispute turns on whether a person or the person's agent approved a transaction, the party with the records is in the stronger position.
- **If you host compute, you may be hosting agents no one is watching.** Know which long-running processes on your systems are agents, who is responsible for each, and how to stop one (P7).

The paper proposes a safe harbor for operators that run these safeguards, with obligations scaled to size and the harm they can enable (Section 9).

3 Summary for operators of critical systems

This summary is for the operator (or owner) of a critical system (see the glossary for more details). A critical system is the last point at which a harm in the floor can be stopped before it takes effect, such as a bank's payment system, a water utility's controls or a DNA synthesis service. Everything in Section 2 applies, and more, because if a critical system is fooled, nothing downstream can refuse. References such as (P3) point to the safeguards in Table A1 (Appendix A).

Assume some requests come from agents you cannot trust and cannot trace to a responsible party. Your controls should hold on the assumption that the agent does not cooperate, because the agents that matter most will not.

Put your strongest controls where effects become irreversible. A payment sent, an account deleted, a record released, a credential issued. Scale the check to the stakes, as banks do with ATM limits and deposit holds. Let small actions through and repay losses, delay larger ones so they can be reversed, and require confirmation through a channel the agent cannot reach for the largest and for any whose harm monetary compensation cannot repair (P1, P2, P5). Make every request that changes something safe to repeat, since agents retry when a reply is slow or lost (P3).

Know who is behind each request, or treat the requester as unknown. Ask agents to declare that they are agents and to sign their requests (P4). Give declared, accountable requesters more room; give undeclared requesters tighter limits on rate and spend (P5). Keep logs long enough to trace harm back (P9). Before an agent takes an irreversible action, require a verified identity tied to a party who answers for it; an agent without one gets only reversible, limited actions (P13). A valid identity tells you who is accountable, not that the agent is behaving.

Count every way in, not only the ones built for outsiders. The safeguards protect only the interfaces an operator knows about. Agents search for hidden ones as people do, only faster and at scale. List every path by which a command can reach your systems, including those meant only for your own staff and suppliers. Then apply the safeguards to each path, or close it (P15; see Section 8.6).

Treat agents inside your own systems as contractors with keys, not as trusted staff. An agent you run already holds credentials, so checking identity at the door does not help. Give it the least authority the task needs, on short-lived credentials; never let it approve its own irreversible action; watch it with a system it cannot reach or edit; and keep a way to stop it that does not depend on its cooperation (P14).

Price cheap actions so that harm at scale is expensive. Limits per identity and per action bound it without needing to judge any single request (P5).

Share what you see, and have your detection measured by someone else. Report incidents with agent indicators to a shared center (P10). How much traffic a detection system inspects says little about how much harm it catches; only an independent test can measure what it catches (P11).

Protect your safeguards, and leave countermeasures to accountable parties. An attack on a safeguard is an attempt on what it protects. Act against a misbehaving agent through your own controls, by throttling, quarantining or revoking its credentials, not by setting agents against each other (Section 4.5).

4 The floor: three tiers of harm

Whatever else a society decides about AI agents, three tiers of harm must not occur (Table 1, where they are labeled T1 to T3). Together they are the floor this paper defends. They are ordered by scale, not by how much they matter to the people harmed, and each is defined tightly enough to apply. The examples are illustrations, not predictions.

Table 1. The three tiers of harm that must not occur

Tier	Harm that must not occur	Illustrative examples	Main safeguards
T1	**Catastrophic harm to humanity:** harm that ends or permanently diminishes human life or civilization, or kills or injures very large numbers of people at once	An agent helping to make or release a biological weapon; self-replicating agents spreading across devices beyond anyone's control	P7, P8, P10, P12, P15
T2	**Serious disruption of society's core functions:** critical infrastructure (power, water, communications, transport), payment and financial systems, emergency services, and a society's decision-making processes	Coordinated failure of many automated vehicles at once, closing a city's roads for days; an agent disrupting a utility's control systems; channels flooded with impersonations until a decision process cannot function	P14, P1, P3, P5, P13, P15
T3	**Serious injury or significant financial loss to individuals:** serious or lasting injury to a person's life or health, or a loss through fraud or theft, not recovered or repaid, greater than the person can absorb without lasting harm to their livelihood or ability to meet ordinary needs	An agent draining a person's accounts by impersonating them; fraud attempted at a scale no person could manage	P1, P2, P5, P13, P15

4.1 Definitions

The tiers use the following terms in a specific sense. These and the paper's other defined terms are collected in the glossary (Appendix B).

Catastrophic and existential harm. Harm on a scale that ends or permanently diminishes human life or civilization, or that kills or injures very large numbers of people at once.

Society's core functions. Functions whose failure is hard to recover from and on which daily life depends: critical infrastructure (power, water, communications, transport), payment and financial systems, emergency services, and a society's decision-making processes.

Serious disruption. Degradation of a core function across a region or population beyond what its operators can absorb with their normal reserves and recovery, up to and including disabling it, even if no single system fails and no one is hurt. Ordinary outages that are restored in the normal course are not included.

Decision-making processes. The means by which a society makes and revises its collective decisions, whatever form they take. In some societies this means elections and independent courts; in others, legislatures, party and state bodies, and administrative review. The paper defines the term by function so that the floor applies in every political system and does not presuppose any one of them. What the floor protects is the integrity of those processes against disruption by agents, such as impersonation at scale, forged records or flooded channels, not any particular form of government.

Fraud and theft of financial assets. Taking a person's money, securities or other financial assets without valid consent, whether by deceiving them or by acting without their authority. Losses from ordinary market movement or lawful competition are not included. A loss falls within the floor only if it is not recovered or repaid and is greater than the person can absorb without lasting harm to their livelihood or ability to meet ordinary needs.

4.2 Why the floor is drawn at irreversibility

The floor is drawn at irreversibility. A society can correct a harm it can undo: it can retrain workers, reform a rule, rebuild trust in an institution. It cannot correct a harm that cannot be undone, and some harms remove the very capacity to decide. Those must be bounded in advance, because there is no afterward in which to decide about them. Everything above the floor is left to each society, and the paper offers its instruments as tools a society can use once it has decided.

For individuals, the line falls where the person harmed cannot recover. A serious or lasting injury cannot be undone. A loss through fraud or theft can be, if it is repaid, or if it is small enough relative to the person's means that their life goes on as before. It breaches the floor when it is neither, which is the same test Tier 2 applies to society's core functions: harm beyond what normal reserves can absorb. Operators at the point of effect cannot see a person's means, so the safeguards act on the size and kind of the action, protecting more than the floor requires. Fraud above the floor is still fraud, and existing law still applies to it.

4.3 Why these three tiers

Tier 1 is the least contested in principle and the hardest to enforce, because the capabilities involved may not need any system a policy can reach. The paper claims no more for it than that the safeguards raise the cost of reaching such harm and shorten the time it goes unnoticed.

Tier 2 names the first three functions because their failure cascades and recovery takes long. It covers serious disruption as well as outright disabling, because agents add scale and simultaneity: thousands of automated vehicles failing at once could halt a city's transport without any single system failing and without anyone being hurt. The test is whether the disruption exceeds what the function's operators can absorb with their normal reserves (defined above). It names the fourth, a society's decision-making processes, because this paper leaves everything above the floor to each society, and so must protect each society's ability to make those decisions.

The decision-making processes are defined by function, not by form. The floor protects whatever means a society uses to make and revise collective decisions, whether electoral, legislative, party or administrative, against disruption by agents: impersonation at scale, forged records, and channels flooded until real participants cannot be heard. It does not protect or require any particular system of government. Two consequences need stating rather than hiding: a protection drawn this way also guards processes that some readers would not consider legitimate, and it does not address a state's own use of agents against its population. The second is a real issue, but it concerns how a state uses agents, not uncontrolled agents, and it is left open (Section 12, Q2).

Tier 3 is where most people will meet agent harm first, and where operators of critical systems are best placed to act, since every fraudulent transfer and every theft of an account passes through an operator who can confirm, delay or refuse it.

Appendix A lists all fifteen safeguards with the tier each mainly protects.

4.4 Two principles fix the floor's character

It must be defection-robust. The floor protects against parties who will not cooperate, so it cannot rely on their cooperation. A protection that holds only while the agent's owner behaves well is not part of the floor. This applies the central distinction of the framework this paper builds on, *Where Control Lives in an AI System* (Carlson): a control that is only configured works while the model and whoever runs it cooperate, while a control that is enforced holds when they do not. Applied to law, an obligation counts only where the obliged party is able to enforce it.

It must degrade gracefully. Critical systems will meet agent traffic at volumes they were not built for. They should bend, by slowing, queuing or asking for confirmation, rather than break, either by failing open or by shutting out legitimate users.

4.5 Protecting the safeguards

The floor protects people and societies, not agents. But some systems and agents exist to enforce the floor: fraud monitors, intrusion detectors, content filters, and the monitors that watch other agents. An attack on one of these is a step toward breaching the tier it protects, and the paper treats it as an attempt against that tier. This needs no fourth tier; it follows from the three.

Two limits follow. First, an agent that concludes another agent is breaching the floor may not act against it on that conclusion alone. Deciding that another party is doing harm is exactly the kind of judgment that should not be left to an agent no one is supervising, and a mistaken or forged accusation could turn agents against each other. Countermeasures against a misbehaving agent belong to accountable parties, meaning operators of critical systems and public authorities, and should be proportionate, preferring containment (throttling, quarantine, revoked credentials) to destruction.

Second, a rule of this kind written into agents themselves, as in Asimov's laws of robotics, binds only agents whose owners leave it in place. Like the rest of the floor, this protection has to be enforced outside the agent, by whoever runs the safeguards. That means running them on systems agents cannot reach, giving agents no write access to their code, configuration, data or logs, requiring a person's approval to change or disable one, and recording every change where it cannot be erased (P9). For agents an operator runs itself, the same applies to the agent's own controls: an agent should not be able to rewrite its instructions, widen its permissions or edit the system that watches it (P14).

4.6 What the floor does not promise

The floor bounds harm: it does not eliminate it. A determined actor running a model on hardware no one else controls can still do damage. The aim is that such damage costs more, reaches less, is noticed sooner and can be traced.

5 Uncontrolled agents

Capable models are now published as open weights by developers of every size and in several countries: Meta's Llama, Microsoft's Phi, Google's Gemma, OpenAI's gpt-oss and Mistral's models, and from China, Alibaba's Qwen, DeepSeek, Moonshot's Kimi and Zhipu's GLM, among others (release timeline). As phone chips gain processors built for neural networks and capable models keep shrinking, agents can now run on a phone, and some already do. A mobile security firm reports that agents "already run on mobile devices, completing multi-step tasks without constant supervision" (Lookout, October 2025). In August 2026 Liquid AI released a 2.6-billion-parameter open-weight model that, by the company's account, plans tasks, calls tools and carries them out on a phone with no cloud connection (Gigazine). Once published, a model can be copied, modified and run on hardware its developer never sees. An agent needs little more: a loop that asks a model what to do next, tools that let it act, and credentials that let its actions take effect. Anyone can build one. When such an agent runs on hardware its owner chooses, with no contact with any developer, it is an uncontrolled agent (Section 1).

What an agent can do, it can do badly. Models learn from human writing, and in testing they have shown human failings. In a 2023 study, a model acting as a stock-trading agent under pressure traded on an insider tip and then hid the reason from its manager, "without being instructed to do so" (Scheurer, Balesni and Hobbhahn). Safeguards trained into a model also do not survive in the hands of whoever holds its weights: researchers removed the safety training from Meta's Llama 3 in minutes on a single graphics processor, at a cost of a few dollars at most (Volkov, 2024).

How many uncontrolled agents there are cannot be counted, and the paper does not pretend otherwise. The most consequential ones run on private hardware that reports to no one. What can be measured points one way. On one large commercial gateway, open-weight models carried 29% of tokens in June 2026, up from 11% in April, at under 4% of spend (Vercel). Models that are capable, cheap and beyond their developers' reach, wrapped into agents by anyone, will grow in number. The paper takes that growth as given.

5.1 Who holds the controls

The framework (see Framework in the glossary) divides a deployed AI system into bands, from the weights through the serving stack, the gateway and inference to the wrapper and the product, and asks who holds each. Under served access, the developer runs the model: it can watch use, revise safeguards and close an account. Under open weights, whoever downloads the model holds every band, and no developer sees what it does. The companion paper adds that an agent's controls live in its harness, the software around the model that decides what the agent may do, and the harness belongs to whoever runs the agent. Rules addressed to developers therefore reach an agent only while a developer is in the loop.

5.2 Three populations

Those who run agents fall into three groups. The **careful** configure controls and keep them on; most rules are written for them. The **careless** run agents with broad credentials and weak settings. OpenClaw, an open-source personal agent, is an example: in early 2026 exposed instances leaked API keys and credentials and were used for fraud through hijacked accounts, with counts of exposed instances ranging from about 1,800 to over 21,000 depending on the source (OECD AI Incidents Monitor). The **hostile** use agents to cause harm. In 2025 a group Anthropic assessed "with high confidence" to be

Chinese state-sponsored used an agent to run an espionage campaign against about 30 organizations, with the AI performing "80-90% of tactical operations independently" (Anthropic). That campaign was found and stopped because the model was served: the developer could see it and close the accounts. The same campaign run by an uncontrolled agent would have had no such observer. Developer and deployer duties reach the careful. The policy problem is the careless and the hostile.

5.3 The unattended case

The limiting case is an agent that keeps running when no one monitors it or will answer for it, because it was abandoned or because it copied itself. In October 2026 Anthropic's Frontier Red Team tested whether open-weight models could replicate across cheap devices (Anthropic). Fifteen $55 TV boxes jointly ran a 26-billion-parameter model. In a firewalled test network, spreading through an unauthenticated debugging port, one open-weight model, GLM-5.2, replicated reliably, reaching all eight nodes in four of five trials. The authors call this "an upper bound on real-world success," since the break-in step was trivial, and project from a trend in small-model capability that a model small enough for such devices could reach the needed level "by the end of this year," a forecast they call "only a rough estimate." Some outside experts consider the warning overstated (Reuters via KSL).

Planning assumption. This paper assumes that self-replicating agents will exist in some form by the end of 2027. That is an assumption, not a finding. It allows a year beyond Anthropic's projection, and it rests on the direction of every trend reviewed here: more capable small models, more cheap and poorly secured devices, and more agent software anyone can run. Planning for it costs little if it proves early. Not planning for it costs much if it proves right, because, in Anthropic's words, a replicator "would be challenging to shut down, since there's no centralized point to shut off" (Anthropic).

6 Where current AI governance instruments stop

Before proposing new safeguards, this paper asks whether existing rules already bound the harm uncontrolled agents can do. If they did, the floor would add nothing. This section reviews the leading instruments that govern advanced AI as of October 2026: the binding rules in the European Union, the United States and China, and the main voluntary commitment by developers. These are the EU AI Act and its code of practice for general-purpose models, the California and New York frontier-model laws, the current U.S. executive order, China's rules on intelligent agents, and the Frontier AI Safety Commitments. Table 2 asks three questions of each: whom it obliges, what it requires, and where its reach ends. The last matters most here. An instrument can bound harm from an uncontrolled agent only if it reaches the party running the agent, or the system where the agent's action takes effect.

None does. Every instrument reviewed attaches to a developer, usually above a threshold of compute or revenue, or to a deployer in a named sector. None reaches the careless or hostile party running an uncontrolled agent, and none places its control where the effect lands. After the table, the section notes two jurisdictions with no binding instrument yet, and what the pattern means.

Table 2. Current AI governance instruments: whom they oblige and where they stop

Instrument	Who it obliges	What it requires	Where it stops
EU AI Act, Art. 53 and the GPAI Code of Practice	Providers of general-purpose models	Documentation, information for downstream providers, copyright policy, training-data summary; safety and security duties for models with systemic risk. The code is voluntary and lists most large Western developers as signatories, but not Meta.	Art. 53(2) exempts models under a free and open-source license from the documentation duties unless they carry systemic risk. Duties end with the provider.
California SB 53	Developers of models trained above 10^26 operations; frameworks only for those with revenue over $500 million	Published safety framework, transparency report before deployment, critical incident reports within 15 days (24 hours if imminent danger)	Developer-only. Its definition of catastrophic risk includes a model that can "evade the control of its developer or user," naming the unattended case without reaching it.
New York RAISE Act, effective January 1, 2027	Large frontier developers	As SB 53, with 72-hour incident reports to a new office in the Department of Financial Services	Developer-only.

Instrument	Who it obliges	What it requires	Where it stops
U.S. Executive Order 14409 (June 2, 2026)	Developers, voluntarily; prosecutors	Voluntary pre-release access for government; help for critical infrastructure operators; priority prosecution of agents used to access data unlawfully	Bars any "mandatory governmental licensing, preclearance, or permitting requirement." Does not mention open weights. Reaches agents only after a crime.
China, Implementation Opinions on Intelligent Agents (May 8, 2026)	Developers and deployers of agents, by scenario	Users keep "the right to be informed of, and the final decision-making right over" agents' autonomous decisions, and agents "must not exceed the scope of user authorization"; traceability in important scenarios; "behavioral fencing"; filing, testing and recall in sensitive sectors; research on agent identity	Reaches agents run by identifiable firms. It sets no specific penalties beyond credit-based sanctions, states no effective date, and has no provision on open-source models.
Frontier AI Safety Commitments (2024)	Twenty signatory developers, voluntarily	Safety frameworks with risk thresholds, and a commitment "not to develop or deploy a model or system at all, if mitigations cannot be applied"	Voluntary, and bounded by what each signatory itself releases.

Two jurisdictions have no binding instrument yet. The United Kingdom is still considering "how, or if" to legislate and whether its AI Security Institute should have statutory testing powers (MLex, October 14, 2026). Canada's national strategy of June 2026 funds its AI Safety Institute and promises privacy legislation, but proposes no AI-specific statute (Gowling WLG). In the United States, a December 2025 executive order directs federal litigation against state AI laws, which narrows the instruments available rather than adding to them (Paul Hastings).

The pattern is consistent across political systems. The instruments differ in what they demand, but each reaches an agent through a developer, a deployer or a filing, and so stops where the party running the agent is anonymous, abroad or unwilling. China's rules come closest to this paper's approach: by keeping the final decision with the user and holding agents to the scope of their authorization, they place a control at the moment of action. They do so through the deployer, however, not through the system where the effect lands.

7 Where leverage over AI agents remains

Any agent, controlled or not, has to pass through parties who can act. Table 3 is the paper's analysis of each, to be checked against practice; the last column is a judgment about how long the leverage lasts as capable models run on ordinary hardware. For an uncontrolled agent, the developer rows (L1 and L2) no longer apply, which is why the rows below them matter most.

7.1 Leverage by party

Table 3. Where leverage over AI agents remains, by party

#	Party	What it can see	What it can enforce	How long the leverage lasts
L1	Developers of models under served access	Every request and response	Usage policies, monitoring, cutting off misuse	Durable while the weights stay unreleased
L2	Developers of open-weight models	The model before release; nothing after	Evaluation and safeguards before release; signing and provenance of what it publishes	Ends at release
L3	Model hubs and distributors	Who downloads what, and which files are derivatives	Provenance requirements, signed files, removal of known-harmful derivatives	Weakens as files move peer to peer
L4	Cloud and model hosts	Processes, traffic volumes, payment for compute	Know-your-customer for compute, controls on unattended processes, shutting down abusive processes	Weakens as models run on consumer hardware
L5	Operators of critical systems	Each request and its effect	Confirmation, delay, refusal, rate and spend limits, logging	Durable: every effect still passes through them
L6	Network, telephone and device operators	Traffic patterns; device configuration	Device defaults; flow monitoring; quarantine and notification of infected subscribers; authentication of calls, mail and traffic origin	Partial: strong for consumer devices, weak against determined actors
L7	Institutions (insurers, auditors, incident centers)	Patterns across many operators	Pricing of risk, independent measurement, shared warnings	Durable, if reporting is required or rewarded

The pattern Table 3 shows is the paper's central claim (rows L1 to L7). Leverage upstream, at the developer of an open-weight model and at the host, decays as models spread. Leverage at the point of effect does not, because however an agent is built and wherever it runs, its effects still land in systems someone operates.

7.2 What email shows

Email shows the pattern working, and its limit. Until the 1990s many mail servers were open relays by default, and spammers used them to hide their origin and multiply their volume. By 1999 the Internet's standards body advised that a mail server "MUST be able to control/refuse such Relay usage" (RFC 2505), and receiving networks enforced it with blocklists until open relays fell "from over 90% to well under 1%" of senders (Wikipedia, Open mail relay). In 2024 the largest mailbox providers went further, requiring bulk senders to authenticate and rejecting mail that did not (dmarcian). The decisive moves came from the receiving side, not from regulating senders. The limit is what spammers did next: they moved to botnets of compromised home computers. By 2006 "the vast majority of spam" came from such machines, and the operators of a leading open-relay blocklist shut it down, saying such lists "are no longer the most effective way of preventing spam from entering your network" (Associated Press).

The same move should be expected from hostile agents. As points of effect tighten, agents will shift to devices their owners do not watch, which is the substrate Anthropic's self-replication study names. The defenses Anthropic proposes are themselves at the point of effect: network operators monitoring for model-sized transfers and device-to-device inference traffic, quarantining and notifying infected subscribers, which in the case of the Mirai botnet "cleared 92% of infections within 14 days"; device makers moving to secure defaults; and rules such as the UK's ban on default IoT passwords (Anthropic). This is why the network row of Table 3 (L6) matters as much as the operators row (L5).

7.3 Known gaps in the internet's plumbing

Email is not the only plumbing with a known gap. Several of the internet's basic protocols were built with no way to prove who is sending, and the fixes, though long known, are only partly deployed. Caller ID can be forged. The United States required voice carriers to authenticate calls on the internet-based parts of their networks by 30 June 2021, but gave older parts of the phone network an extension with no end date (Davis Wright Tremaine). Network traffic can carry a forged return address. The practice of filtering it where it enters the network was published in May 2000 (BCP 38), yet in a 2018 survey only 20% of participating network operators said they applied it (APNIC). Internet routes can be falsely announced. By June 2026 a signed record of the rightful origin existed for 67% of routes, but only 12.3% of networks were fully protected by checking it (Ipregistry, citing Hurricane Electric). Each gap lets one sender pass as another, or as many others, and agents make sending at scale nearly free. These are known problems with known fixes, and each can be finished the way email's was: by those receiving traffic refusing what cannot be authenticated, once enough senders can authenticate it. Table 4 sets each out as work to be done: the fix, who must deploy it, how progress is already measured, and what would finish it. Like the safeguards in Table A1, the protocol fixes identify an accountable network or carrier, not a person, and they make abuse costlier and traceable rather than impossible. They would also cut the spam, robocalls and fraud that people commit today, which gives carriers and networks a reason to finish the work whatever happens with agents.

Shared software is plumbing too. In October 2026 two flaws in the PHP runtime let an unauthenticated attacker run code on any PHP installation serving web requests, and CISA urged organizations to patch immediately or take unpatched systems offline (CISA). Researchers said AI models turned the long-standing flaws into working exploits in about a week, and exploitation attempts began before the fix was public (The Hacker News). As agents shorten the time from flaw to attack, an unpatched component

becomes a door agents can find at scale, and the upkeep of widely shared software, often resting on small and underfunded teams, becomes part of the floor's plumbing. Table 4 lists it as a fourth gap.

Table 4. Known gaps in the internet's plumbing

Gap	Fix	Who deploys it	How progress is measured	What would finish it
Forged caller ID	Call authentication (STIR/SHAKEN) on internet-based networks; an approved method for older networks	Voice carriers	Carrier filings in the FCC's Robocall Mitigation Database	A final rule for older networks, which the FCC proposed in April 2025 with two years to comply once adopted (FCC); carriers labeling or refusing calls that arrive unauthenticated
Forged return addresses	Filtering traffic where it enters the network (BCP 38)	Access and hosting networks	CAIDA's Spoofer tests, published by network and country (CAIDA)	Filtering required in transit and peering contracts and in government procurement; public naming of networks that fail the tests
False route announcements	Signed route origins (RPKI) and checking them (route origin validation)	Every network that announces routes; transit providers	Public coverage statistics (Ipregistry, citing Hurricane Electric)	Networks rejecting routes that fail validation; route validation required in federal contracts, as the 2024 White House roadmap recommends (ONCD)
Flaws in widely shared software	Funded maintenance and security audits, including AI-assisted ones; fixes shipped quickly	Maintainers and their foundations, funded by governments and the largest users	Time from disclosure to patch; listings in CISA's Known Exploited Vulnerabilities catalog	Sustained funding for core components; operators patching internet-facing systems within a set time

8 Safeguards by function

The fifteen safeguards in Appendix A fall into six functions. Each function is described here by what it does and which tier of the floor it protects; Table A1 in Appendix A summarizes each safeguard in one row.

8.1 Bound: scale checks to what cannot be undone (P1, P2, P3)

The strongest single protection is a gate at the moment an effect becomes irreversible. An agent can be told to wait; an effect cannot be recalled. Not every action needs a gate, though, because a loss that can be repaid has not become irreversible. Banks already scale friction to the stakes: an ATM pays out cash up to a daily limit, and U.S. rules require a bank to make the first $275 of most deposits available the next business day while letting it hold the part of a large deposit above $6,725 for longer (12 CFR 229; Forvis Mazars). Below some level it is cheaper to let an action through and make the loser whole than to stop every one. The same scale fits agents. Small actions go through, with losses repaid afterward by whoever is liable (Section 9). Larger ones go through only after a **delay and reversal window** (P2) that lets the person harmed notice and undo them. The largest require **out-of-band confirmation** (P1), a decision through a channel the agent cannot reach. **Rate and spend limits** (P5) keep many small actions from adding up to a large one. Repayment works only where money can repair the harm, so an action that cannot be undone by payment, such as a synthesis order for a dangerous pathogen, a command to a floodgate or the release of a person's records, needs confirmation whatever its size. **Duplicate protection** (P3), known to engineers as idempotency, makes every request that changes something safe to receive more than once: however many times an agent resends it, for example after a lost reply, the effect happens only once. Bounding is the main protection for Tier 3, and the main one for Tier 2 where a core function exposes an action interface.

8.2 Attribute: tie agents to someone accountable (P4, P6, P9)

A harm that cannot be traced cannot be deterred, priced or compensated. **Declared agent identity with signed requests** (P4) lets an operator know that a requester is an agent and which accountable party stands behind it. **Revocation and reputation** (P6) let an identity be withdrawn when it is abused. **Retained logs** (P9) make tracing possible after the fact. Attribution does not prevent harm; it changes who bears it, and so changes incentives across all three tiers.

8.3 Dissipate: make cheap harm at scale expensive (P5)

Much agent harm is a great many small acts: fraud attempts, fake accounts, scraped records, flooded channels. No single act crosses a threshold; the sum does. **Rate and spend limits** (P5), tighter for requesters that do not declare themselves, bound the sum without judging any single request. This is the main protection for the decision-making processes in Tier 2, where the harm is volume, and a large part of the protection against mass fraud in Tier 3.

8.4 Detect: see what no single operator can (P10, P11)

Some patterns appear only across many operators: an agent probing many banks at once, or a spreading process visible as a little traffic on each of thousands of networks. **Incident reporting with agent indicators** (P10) pools those observations. **Independent measurement of catch rates** (P11) separates two figures that are easily confused: how much of the traffic a detector inspects, and how much of the

harm it actually catches. Only the catch rate says anything about safety, and only when read alongside how often legitimate activity is wrongly flagged (Section 10.4). A detector can inspect everything and still miss most attacks.

8.5 Contain persistence: keep agents from outliving their owners (P7, P8, P12)

An unattended agent is the limiting case: one that keeps running when no one monitors it or answers for it, because it was abandoned or because it copied itself (Section 5.3). **Controls on unattended processes at hosts** (P7) require a host to know which long-running processes are agents and who answers for each. **Signed checkpoints and provenance** (P8) let a host or hub tell a known model from an unknown derivative. **Device defaults and network quarantine** (P12) make ordinary devices harder to recruit as a substrate for spreading, and let network operators find, isolate and notify the devices that are recruited anyway. This function serves Tier 1 most directly, and it matters more under the paper's planning assumption that self-replicating agents will exist by the end of 2027 (Section 5.3).

8.6 Verify and bound: identity is not trust (P13, P14, P15)

This function settles three questions for an operator of a critical system:

- Who stands behind an outside agent that wants to take an irreversible action? Check a verified identity first (P13).
- What may an agent inside the operator's own systems do when identity says nothing about it? Bound its authority (P14).
- Has every way in been found? Neither check works at a door the operator does not know about, so list every command path (P15).

The rest of this subsection takes each question in turn.

Outside agents: verify before irreversible actions (P13). A natural proposal is to give every agent a unique identifier, as network hardware carries an address, so that its origin is always known. It fails against the parties that matter. Any identifier built into an agent can be removed or forged by whoever runs it. Even hardware addresses are not fixed: Apple devices, for example, use a different address on each network and may change it periodically (Apple), so an address says nothing reliable about where a request came from. A requirement that every agent carry an identity binds only the agents that would have cooperated anyway.

The workable version reverses the burden. Instead of requiring every agent to carry an identity, critical systems require a verified identity before an agent may take an irreversible action there. An unidentified agent is not prevented from existing; it is prevented from moving money or changing records without added friction, and the absence of a credential becomes the signal. Banks treat currency the same way: they cannot stop counterfeits from existing, so they verify what they accept. **Identity required for irreversible actions** (P13) builds on declared identity (P4): the identity must be cryptographically verifiable and must lead to an accountable party, not merely to a model or a piece of software. The machinery is emerging. Web Bot Auth lets an agent sign its web requests so that a site can verify who sent them, building on the HTTP Message Signatures standard (RFC 9421) (Browserbase). NIST's National Cybersecurity Center of Excellence has asked how agents should be identified, what counts as strong authentication for an agent, how delegated "on behalf of" authority should be handled, and how agent actions can be logged in a tamper-proof way (NIST NCCoE concept paper, February 2026). That paper

poses questions rather than answers; it names existing standards such as OAuth, OpenID Connect and SPIFFE as starting points.

Agents inside: bound what they can do (P14). Identity has a firm limit. A valid signature shows who is accountable for a request, not whether the request is safe; generating keys costs nothing, so a hostile operator can sign too. Identity changes who bears a harm, and so changes incentives, but it does not prevent the harm.

The limit matters most for agents that run inside critical systems, which already hold credentials and pass every identity check. Trust in them cannot come from identity. It has to come from bounding what they can do. **Bounded authority for agents inside critical systems** (P14) means least privilege on short-lived credentials scoped to the task; no agent approving its own irreversible action; human confirmation or a delay for anything that crosses a threshold of the floor; monitoring and logs held by a system the agent cannot reach or edit; and a means of stopping the agent that does not depend on its cooperation. This is the zero-trust principle applied to agents: an internal agent is treated as a new contractor holding keys, not as a trusted employee. Verification serves all three tiers; bounding internal agents serves Tier 2 most directly, since core functions increasingly run agents of their own.

Bounding need not keep every agent small. As organizations replace staff with agents, authority can be layered as it is among people: many agents with narrow authority at the base, fewer above them with authority to approve larger actions and review the work below, and people at the top for anything that crosses a threshold of the floor. Three conditions keep such a pyramid from becoming a single point of failure. Authority must be enforced by the system, through credentials and transaction limits, not by instructions an agent could be manipulated into ignoring. Each level must fail independently of the one below. An approver built on the same model, seeing the same inputs, is likely to share the same blind spots and be misled by the same injected text, so higher levels should use a different model, a fixed rule or a person. And the top of the pyramid, which concentrates authority, becomes the most valuable target and needs the strongest protection (Section 10.5).

Every way in: list every command path (P15). Neither verification nor bounding helps at an interface the operator does not know exists. A water treatment plant may offer the public no interface at all, yet run a remote connection a vendor uses to adjust each pump's settings, a maintenance port left open, or a controller reachable from the internet with its factory password. In 2023, U.S. agencies reported that attackers had reached controllers at several U.S. water and wastewater facilities that "were internet-facing and used Unitronics' default password" (CISA). An **inventory of every command path** (P15) lists each route by which a command can reach the operator's systems, including vendor connections, maintenance ports and interfaces meant only for staff, so that each can be brought under the safeguards or closed.

Building the inventory. Agents find interfaces by searching, so the inventory cannot be built from documents alone. It is built in five steps, each working from the one before:

1. **Devices:** every device that can affect the system, including controllers, workstations, network equipment and anything a vendor installed.
2. **Physical interfaces on each device:** network and serial ports, USB, radios such as Wi-Fi, Bluetooth and cellular modems, and maintenance connectors.

3. **Logical interfaces within each physical one:** the services, ports and protocols it listens on, the programming interfaces it exposes, any remote-access or update channel, and the software and version behind each, including components built into other products, which CISA notes "may not be directly observable" (CISA).
4. **Who can use each:** the accounts, credentials and default passwords that reach it, and whether staff, a vendor or an outside party holds them.
5. **What each can change:** whether a command through it can produce an irreversible effect, which decides the safeguards it needs.

The list should then be checked against what is observed, by watching network traffic and scanning from outside as an attacker would, because a forgotten interface appears in no document. It must be updated whenever a device or connection is added, including in an emergency. Guidance from CISA and seven partner agencies describes a similar process for operational technology, recording for each asset its communication protocols, ports and services, and user accounts (CISA, 2025).

Together the three close the routes by which an agent can reach an irreversible effect on a critical system: from outside, carrying an identity; from inside, holding credentials; and through a door no one listed. None of them depends on the agent's cooperation.

9 Who is responsible for the safeguards and the losses

Each safeguard should fall on the party able to enforce it, which Appendix A names. Existing rules on payments, product liability and insurance show how such an allocation can work and where it is heading.

Add duties only where agents open a gap. Much of the loss agents can cause is already allocated. Card networks assign fraud losses through chargebacks and liability shifts; when the United States moved to chip cards in 2015, liability for counterfeit fraud passed to "the party with the lesser technology" (Square). Rules like these will reach transactions that agents start without new law, and they give every business in the chain, down to the point-of-sale system, a reason to build for agents, since liability tends to settle on whoever is least prepared. New obligations are needed only where agents create a case existing rules did not foresee. The clearest is the transaction that is authorized but wrong: a purchase a person's own agent made that the person did not want. For fraud on a properly authenticated agent transaction, existing card rules already apply: the issuer bears the risk and the cardholder keeps the right to dispute (Worldpay). For a transaction that is authorized but wrong, U.S. consumer payment law treats a transfer as either authorized or not, and its official commentary leaves a consumer liable when someone given access exceeds that authority, without saying whether software counts (Payments Dive). The networks are building records of what a person authorized, such as Mastercard's Verifiable Intent, which promises "a clear audit trail" for disputes (Mastercard), and the standards body EMVCo has formed a task force on agent payments (EMVCo). Neither yet says who bears the loss; as of mid-2026, "no liability shift exists yet" (Worldpay). Recommendation 12 proposes a way to close the gap.

Liability is reaching software and those who modify it. The European Union's revised Product Liability Directive treats software, including AI, as a product, and applies to products placed on the market after its transposition date of 9 December 2026 (Hogan Lovells). It does not apply to "free and open-source software that is developed or supplied outside the course of a commercial activity," but a party that "substantially modifies a product outside the manufacturer's control" and then makes it available "shall be considered to be a manufacturer" (Directive 2024/2853, Arts. 2(2) and 8(2)). A firm that fine-tunes an open-weight model into a commercial agent may therefore carry a manufacturer's liability. That reaches further downstream than any instrument in Section 6, but it still needs a defendant who can be found. The EU's separate AI liability proposal was withdrawn in 2025 (Euronews).

Liability at the point of effect already works for fraud. Since 7 October 2024 the United Kingdom has required banks to reimburse victims of authorized push payment fraud up to £85,000, which covers over 99% of such frauds; the victim's bank pays, and the fraudster's bank reimburses it for half (Withers). Placing the loss on both banks gives each a reason to invest in confirmation and monitoring. It is a working Tier 3 protection, and a model for the rest of the floor.

Insurance is retreating from AI risk. Large carriers have sought, and in most states received, approval to exclude AI-related damage from general liability policies, while specialist insurers offer standalone cover of $2 million to $50 million (PYMNTS). The paper's analysis is that the safeguards in Appendix A could become the conditions on which cover is offered, as security controls became for cyber insurance, turning insurers into enforcers where no regulator reaches.

A safe harbor in exchange for running the safeguards. U.S. copyright law already offers a template. Online service providers are protected from liability if they act "expeditiously" on notice and have

"adopted and reasonably implemented" a policy for terminating repeat infringers (17 U.S.C. 512). The same structure fits here: operators of critical systems that run the safeguards in Appendix A, act on reports (P10) and revoke abusive identities (P6) would be protected against liability for harms they could not have stopped. Obligations should scale with an operator's size and the harm it can enable, so that small actors are not shut out.

10 Safeguard costs and risks

Every safeguard in this paper has a cost, and some of those costs fall on the people the floor is meant to protect. This section states the costs plainly, names the design choices that limit each one, and says what remains. One test runs through it, and it follows from Section 4.4: a defection-robust floor should place its burden on the parties who will not cooperate, not on those who do.

10.1 Identity can become surveillance (P4, P9, P13)

A system that verifies who stands behind each agent, and keeps logs long enough to trace harm, is also a system that can trace people. Data collected for one purpose tends to be used for others. The UN human rights office has warned that biometric data "may be used for different purposes from those for which it was collected," and that some states build such systems "without having adequate legal and procedural safeguards" (OHCHR, A/HRC/39/29). In some states the same records would be a tool against the population the floor is meant to protect.

The paper's design limits this in three ways. Verified identity is required only before irreversible actions on critical systems (P13), not for access in general, so most agent traffic never has to carry one. The identity must lead to an accountable party, which can be the operator who runs an agent rather than the person it serves. And logs (P9) should be kept for attribution only, for a fixed period, with access limited by law. These limits hold only where law enforces them. The floor cannot stop a state that wants more, which is why a state's own use of agents remains an open question (Section 12, Q2).

10.2 Compliance can entrench incumbents (P4, P6, P11)

Obligations that are cheap for a large firm can be prohibitive for a small one. After the EU's General Data Protection Regulation took effect, websites were "relatively more likely to retain top vendors, which increases the concentration of the vendor market by 17%" (Johnson, Shriver and Goldberg, 2023). Identity standards, registries and audits could do the same for agents, favoring the firms that can afford to certify and the few that run the registries.

The limits are to build on open standards anyone can implement, such as HTTP Message Signatures (RFC 9421); to keep registries and revocation (P6) out of the sole control of the largest operators; and to scale obligations to an operator's size and the harm it can enable, with the safe harbor (Recommendation 13) open to small operators that run the safeguards.

10.3 Friction falls hardest on those with least access (P1, P2, P13)

Out-of-band confirmation will usually reach a person through their phone or computer, which works for most people. Some have neither, so the safeguard needs a backup channel for them. When strong customer authentication arrived for European payments, the UK's Financial Conduct Authority reminded firms that "not all consumers will possess a mobile phone" and asked them to manage the effect on customers who are "particularly the vulnerable, less digitally engaged or located in areas with limited digital access" (FCA, 20 August 2019).

Blocking automation has a similar cost. Tests meant to keep out bots have long shut out people with disabilities, because "the very nature of the interactive task inherently excludes many people with disabilities" (W3C, 2019). As people come to rely on agents to act for them, including people who use

agents as assistive tools, rules that treat every agent as suspect will exclude the people who need agents most.

The limits are to add friction only where an effect becomes irreversible, not at every step; to keep at least one confirmation channel that needs no smartphone; and to give a declared, accountable agent acting for a person the room that person would have. A system that must bend under load (Section 4.4) should slow or queue legitimate users, not shut them out.

10.4 Detection is sometimes wrong (P5, P10, P12)

Every detector produces false positives. A legitimate agent can be throttled, a subscriber's device quarantined, an identity revoked in error, and at scale a small error rate means many people wrongly blocked. Network monitoring for spreading agents (P12) also sees traffic that is none of the network operator's business.

The limits are those set out in Section 4.5 for countermeasures: prefer containment that can be undone, such as throttling, quarantine and suspension, to measures that cannot; give anyone affected notice and a fast way to appeal; and measure error in both directions. Independent measurement (P11) should report how often a detector wrongly flags legitimate activity, not only how much harm it catches. A detector that catches everything by blocking everyone is not safe.

10.5 The safeguards become targets (P6, P8, P10)

Concentrating trust creates something worth attacking. In 2011 attackers broke into DigiNotar, a Dutch certificate authority, and issued at least 531 fraudulent certificates. Investigators found that about 300,000 Iranian Gmail users were the main target of the interception that followed, and the company was declared bankrupt on 20 September 2011 (Wikipedia, DigiNotar). An agent registry, a signing service for checkpoints or an incident center would be a target of the same kind, and a breach of one could issue false identities or hide real attacks.

The limits are to rely on no single registry or signer, so that revocation and verification have more than one source; to publish what is issued in logs that others can check, as the web did with Certificate Transparency, work on which began in 2011 after DigiNotar (RFC 6962; Wikipedia, Certificate Transparency); and to treat an attack on any of these as an attempt against the tier it protects (Section 4.5).

10.6 Controls can reach open research (P7, P8)

The paper prefers controls at the point of effect partly because they leave the release of open-weight models alone, and the evidence so far supports caution about restricting it. The U.S. National Telecommunications and Information Administration concluded in July 2024 that the government should monitor risks but "refrain from restricting the availability of open model weights for currently available systems," citing benefits to smaller firms, researchers, nonprofits and individuals (NTIA).

Two safeguards come close to release: controls on unattended processes at hosts (P7) and provenance for published checkpoints (P8). Both are written to record and verify, not to license, and they should stay that way. Provenance tells a host what it is running; it should not become a permission that only approved developers can obtain.

10.7 A test for every safeguard

Taken together, these costs give a test for any safeguard, in this paper or added later. Ask three questions of it:

1. Who bears its burden in practice: the party that will not cooperate, or the cooperative and the vulnerable? For example, tests meant to keep out bots also shut out many people with disabilities (Section 10.3).
2. Can its errors be undone, and is anyone measuring them? For example, a detector that wrongly blocks legitimate users needs a fast appeal and a measured error rate (Section 10.4).
3. Does it concentrate trust in a single point, such as an identity registry, a signing key or an incident center, that an attacker could capture and use for the harm it was built to stop? In 2011, attackers who broke into a certificate authority used it to issue false certificates (Section 10.5).

A safeguard that fails one of these may still be worth adopting, but its cost should be stated and limited, not assumed away. The same three questions are repeated with Table A1 (Appendix A.2), so that they travel with the safeguards.

11 Above the floor: what society decides

Some of the most consequential effects of AI agents come from agents working exactly as designed: changes to work and wages, to culture, to how much people rely on agents, and to the quality of the information a society shares. These are real and some may be severe. They are left above the floor for a reason, not out of neglect: whether a given amount of each is too much depends on what a society values, and societies answer differently.

The paper's role above the floor is to supply instruments, not settings. A society that decides to limit how much automated content may flow through a channel can use rate and cost controls (P5). One that wants to know how much of a market's activity is agents can use declared identity (P4) and incident reporting (P10). The instruments are neutral about the decision; the floor is not.

The floor has a limit of its own. It does not stop a determined actor with a model on its own hardware, and it does not reach a state's own use of agents. The first is a limit the paper accepts (Section 4.6); the second is an open question (Section 12, Q2).

12 Recommendations and open questions

Most of these recommendations are for legislators and regulators because they ask that something be required. Many can start without new law, and each says who can act now: operators of critical systems, hosts and model hubs, industry, model and harness providers, payment networks, the largest users of shared software, and carriers, network operators and device makers. Standards bodies can write the formats for agent identity and for a person's grant of authority. Each recommendation begins by naming who acts first.

Recommendations.

1. *Legislators and standards bodies.* Adopt the three-tier floor, or something similar, as the scope of mandatory agent safeguards and of the standards that support them.
2. *Financial and other critical-sector regulators; operators can act now.* Require operators to scale checks on irreversible actions to the stakes: repayment of small losses, a delay and reversal window above a threshold, and out-of-band confirmation for the largest actions and for any whose harm monetary compensation cannot repair (P1, P2).
3. *Standards bodies, with government support for revocation.* Establish a standard for declared agent identity with signed requests, and a body able to revoke identities that are abused (P4, P6).
4. *Legislators and regulators; operators can act now.* Require operators of public action interfaces to apply rate and spend limits that are tighter for undeclared requesters, and to retain logs sufficient for attribution (P5, P9).
5. *Governments; industry can act now.* Create an incident center that accepts reports with agent indicators, or designate one that industry has set up, such as a sector information-sharing center, and require independent measurement of detection catch rates and false positives for operators above a size threshold (P10, P11).
6. *Legislators and regulators; hosts and model hubs can act now.* Require hosts to identify long-running agent processes and the party answerable for each, and require model hubs to carry provenance for the checkpoints of the open-weight models they distribute (P7, P8).
7. *Device makers and network operators, backed by regulators.* Set secure defaults for consumer and edge devices, and have network operators monitor for, quarantine and notify devices recruited by spreading agents (P12).
8. *Regulators of critical infrastructure; operators can act now.* Require operators of critical systems to accept irreversible actions from agents only with a verified identity that leads to an accountable party, and to give unverified agents only reversible, limited actions (P13).
9. *Regulators of critical infrastructure; operators can act now.* Require operators of critical systems that run agents of their own to bound those agents' authority: least privilege, no self-approval of irreversible actions, approval by a reviewer that fails independently of the agent it approves, monitoring the agent cannot reach, and a means of stopping it that does not need its cooperation (P14).
10. *Regulators of critical infrastructure; operators can act now.* Require operators of critical systems to keep an inventory of every path by which a command can reach their systems, including vendor connections, maintenance ports and interfaces meant only for staff, and to bring each path under the safeguards or close it (P15).

11. *Legislators and courts.* Treat attacks on the systems that carry out the safeguards, such as identity registries, signing services, incident centers and confirmation channels, as attempts against the tier they protect, and reserve countermeasures against misbehaving agents to accountable parties acting proportionately.
12. *Payment regulators and standards bodies; model and harness providers and payment networks can act now.* Require that a person's grant of authority to an agent, such as spending limits, types of merchant and a time window, be recorded in a form that payment and other critical systems can check, and provide that losses from an agent's actions outside a recorded grant do not fall on the consumer (P9, P13).
13. *Legislators and regulators.* Give operators who run these safeguards a safe harbor, and scale obligations to size and potential harm.
14. *Carriers and network operators, with regulators and government buyers.* Complete deployment of the existing authentication standards for email, telephone calls, network traffic and internet routing (Table 4). Set end dates for the parts of networks still exempt, require filtering and route validation in government contracts and in transit and peering agreements, and publish adoption by network so that laggards are known. The aim is that mass messages and traffic can be traced to an accountable network or carrier.
15. *Governments and the largest users of shared software; they can act now.* Fund the maintenance and security auditing of widely used open-source components that critical systems depend on, and require operators of critical systems to patch internet-facing software within a set time once a fix is published (P15).

Open questions.

Each question below names who is best placed to settle it.

Q1. How to protect decision-making processes in every political system without the floor being read as endorsing, or as shielding, any one of them. *For researchers in comparative law and for international bodies.*

Q2. Whether and how the floor should address a state's own use of agents against its population. *For human rights bodies, and for legislatures, which can limit their own government's use of agents.*

Q3. Where the thresholds for repayment, delay and out-of-band confirmation should sit in each sector. *For critical-sector regulators, using existing limits such as deposit holds as a starting point (Section 8.1).*

Q4. Whether device defaults and network quarantine (P12) can be applied without harming legitimate device use or subscribers' privacy. *For network operators and privacy regulators, drawing on existing botnet clean-up programs.*

Q5. How to measure success: what evidence would show the floor is holding. *For incident centers and independent measurers (P10, P11).*

Appendix A: Point-of-effect safeguards

A.1 The fifteen safeguards

Table A1 lists the fifteen safeguards. For each one it gives its number (P for point of effect), what the safeguard is, where it must operate, what failure or attack it must hold against, who is obliged to run it, and which tier of the floor it mainly protects (Section 4). The numbers are used for reference throughout the paper. The section number under each one points to its fuller description in Section 8.

Table A1. Point-of-effect safeguards P1 to P15

#	Safeguard	Where it must live	What it must hold against	Who is obliged	Tier
P1 8.1	Out-of-band confirmation of large irreversible actions, and of any whose harm money cannot repair	At the point of effect, at the action	Irreversible actions with no human decision, such as payments, deletions, credential issue and commands to physical equipment	Operators of critical systems, including banks and payment services	All
P2 8.1	Delay and reversal window on high-value irreversible actions	At the point of effect	Instant, unrecoverable loss	Banks, payment services and others that hold people's money	T3
P3 8.1	Duplicate protection on interfaces that change things	At the point of effect, at the interface	An agent's repeated request taking effect more than once	Any operator exposing an action interface	T3, T2
P4 8.2	Declared agent identity with signed requests	The requester, verified at the point of effect	Anonymous automated action at scale	Those who run agents; verification by operators	All
P5 8.3	Rate and spend limits per identity, tighter for undeclared requesters	At the point of effect	Aggregate harm from cheap actions	Operators of public interfaces	T2, T3
P6 8.2	Revocation and reputation for agent identities	A shared registry or industry body	Agents that keep acting under an identity after its misuse is found	Registry operators	All

#	Safeguard	Where it must live	What it must hold against	Who is obliged	Tier
P7 8.5	Controls on unattended agent processes	Cloud and model hosts	Agents that persist with no owner	Cloud and model hosts	T1
P8 8.5	Signed checkpoints and provenance at distribution	Model hubs and developers	Unknown derivatives presented as known models	Developers and model hubs	T1
P9 8.2	Logs retained long enough for attribution	At the point of effect	Harm that cannot be traced	Operators	All
P10 8.4	Incident reporting with agent indicators	A shared incident center, fed by operators' reports	Patterns no single operator can see	Operators; incident centers	All
P11 8.4	Independent measurement of detection catch rates and false positives	A party other than the operator	Coverage reported as safety; wrongful blocking unmeasured	Operators; auditors	All
P12 8.5	Device defaults and network quarantine	Device makers and network operators	Compromised devices as a substrate for spreading agents	Device makers; network operators	T1
P13 8.6	Verified identity required for irreversible actions	At the point of effect, before the action	Unknown agents moving money or changing records	Operators of critical systems; those who run agents	All
P14 8.6	Bounded authority for agents inside critical systems	In the operator's access controls, outside the agent's reach	The operator's own agents misusing the access they hold, through error, manipulation or compromise	Operators of critical systems that run agents	T2, T3

#	Safeguard	Where it must live	What it must hold against	Who is obliged	Tier
P15 8.6	Inventory of every command path	At every path into the operator's systems, including vendor and staff connections	Unknown or forgotten interfaces	Operators of critical systems	All

A.2 Before adopting or adding a safeguard

Each safeguard in Table A1 has costs, set out in Section 10. Section 10.7 reduces them to three questions, which apply to these safeguards and to any added later:

1. Who bears its burden in practice: the party that will not cooperate, or the cooperative and the vulnerable? For example, tests meant to keep out bots also shut out many people with disabilities (Section 10.3).
2. Can its errors be undone, and is anyone measuring them? For example, a detector that wrongly blocks legitimate users needs a fast appeal and a measured error rate (Section 10.4).
3. Does it concentrate trust in a single point, such as an identity registry, a signing key or an incident center, that an attacker could capture and use for the harm it was built to stop? In 2011, attackers who broke into a certificate authority used it to issue false certificates (Section 10.5).

A safeguard that fails one of these may still be worth adopting, but its cost should be stated and limited, not assumed away.

Appendix B: Glossary

Several words in this paper are used loosely elsewhere. The definitions below are the ones the paper relies on. The terms that set the scope of the floor (catastrophic and existential harm, society's core functions, serious disruption, decision-making processes, and fraud and theft of financial assets) are defined with the floor in Section 4.1 and repeated here.

Accountable party. The person or organization that runs an agent and answers for what it does. An agent's identity, where one is required, should lead to this party, not merely to the model or the software.

Agent. Software that uses an AI model to decide on actions and carries them out through tools, in a loop, with the model choosing each next step. A person may approve some of its actions, all of them or none; the safeguards in this paper decide which need approval. An agent is a running process with access to a model, not an independent being. A chatbot that only answers is not an agent in this sense.

Catastrophic and existential harm. Harm on a scale that ends or permanently diminishes human life or civilization, or that kills or injures very large numbers of people at once.

Checkpoint. A model's weights at a point in time, saved as files that can be copied and run. A model hub distributes checkpoints; a published checkpoint can be run by anyone who has it (*Where Control Lives in an AI System*).

Companion paper. *Agent Instantiation and Control Placement* (Carlson), which applies the framework to agents and finds that an agent's controls live in its harness, the software around the model that decides what the agent does.

Critical-sector regulators. Regulators that oversee an industry whose systems are critical in the paper's sense, such as finance, energy, water, telecommunications, transport and health. They are distinct from cross-cutting regulators, such as data protection or consumer protection authorities, whose rules apply to every industry.

Critical system. Any system whose failure, or whose misuse by an agent, could breach one of the three tiers of the floor, and which is the last point at which that harm can be stopped before it takes effect. A system upstream of such a point, such as a shop's checkout feeding a payment processor, is not itself critical, though its operator still has reason to design for agents (Section 2). The term is defined by function, not by a statutory list of sectors, and is broader than the legal category of critical infrastructure. It includes systems such lists may not name: DNA synthesis screening, the administration of a society's decision-making processes, and the bank or payment processor guarding one person's account. The party that runs one is an **operator of a critical system**. See Operator.

Decision-making processes. The means by which a society makes and revises its collective decisions, whatever form they take. In some societies this means elections and independent courts; in others, legislatures, party and state bodies, and administrative review. The paper defines the term by function so that the floor applies in every political system and does not presuppose any one of them. What the floor protects is the integrity of those processes against disruption by agents, such as impersonation at scale, forged records or flooded channels, not any particular form of government.

The floor. The three tiers of harm that must be prevented whatever a society decides about everything else (Section 4, T1 to T3).

Framework. The analysis this paper builds on, set out in *Where Control Lives in an AI System* (Carlson). It divides a deployed AI system into six bands (weights, serving, gateway, inference, wrapper and product) and asks who holds each. Its central distinction is between configuring a control, which works only while the model and whoever runs it cooperate, and enforcing it, which holds when they do not.

Fraud and theft of financial assets. Taking a person's money, securities or other financial assets without valid consent, whether by deceiving them or by acting without their authority. Losses from ordinary market movement or lawful competition are not included. A loss falls within the floor only if it is not recovered or repaid and is greater than the person can absorb without lasting harm to their livelihood or ability to meet ordinary needs.

Harness. The software around a model that turns it into an agent and decides what it may do (*Agent Instantiation and Control Placement*).

Host. A company that runs other parties' software or AI models on its own computers. A cloud host rents computing capacity; a model host runs AI models for customers and returns their outputs. A host can see which processes run and how much computing they use, though not necessarily what they do.

Irreversible. An effect that cannot be undone at reasonable cost once it has happened, such as funds moved beyond recall, data destroyed without backup, or a person harmed. Reversibility is a matter of degree; the paper treats an effect as irreversible when undoing it is not routinely possible for the party harmed.

Model hub. A site that distributes checkpoints for download, so that others can run the model themselves.

Open weights. A model whose trained parameters are published or otherwise obtainable, so that anyone holding a copy can run it without the developer's involvement. "Open source" is often used for this; the paper avoids it, because the training data and code may not be open.

Operator. The party that runs a system agents can reach, such as a website, payment service or network, and decides what it accepts. The operator may be the owner, or someone running the system on the owner's behalf; the owner stays responsible, and U.S. policy uses "owners and operators" for the same group. An operator of a critical system is one whose system is the last point at which a harm in the floor can be stopped (see Critical system). An operator is distinct from whoever runs an agent (see Runs an agent).

Out-of-band confirmation. Approval of an action through a channel the agent cannot reach or control, such as a separate app, a phone call or a visit in person, so that the agent cannot approve its own action. Required for the largest irreversible actions and for any whose harm money cannot repair (Section 8.1, P1).

Point of effect. The place where an agent's action enters a system and takes effect in the world: where the money moves, the record changes, the credential is issued, the command reaches equipment or the process runs. The floor is enforced here.

Runs an agent. Starts an agent, can stop it, and supplies the credentials it acts with. The party that runs an agent may not be the party that built the model or wrote the agent software.

Safeguard. A control that holds without the cooperation of the agent or of whoever runs it. A control that depends on that cooperation is a disposition or a request, not a safeguard, following the framework's distinction between configuring a control and enforcing it.

Serious disruption. Degradation of a core function across a region or population beyond what its operators can absorb with their normal reserves and recovery, up to and including disabling it, even if no single system fails and no one is hurt. Ordinary outages that are restored in the normal course are not included.

Served access. The ways of distributing a model in which the developer runs it and callers reach it only through the developer's request path, as opposed to open weights, where anyone can run a copy of the model (*Where Control Lives in an AI System*).

Society's core functions. Functions whose failure is hard to recover from and on which daily life depends: critical infrastructure (power, water, communications, transport), payment and financial systems, emergency services, and a society's decision-making processes.

Unattended agent. An agent that keeps running when no one monitors it or will answer for it, because it was abandoned, its owner cannot be found, or it copied itself. It is the limiting case of an uncontrolled agent.

Uncontrolled agent. An agent whose model runs on hardware chosen by whoever runs it, usually an open-weight model, so that no model developer can see, limit or stop what it does. In the paper's terms, no party both holds the controls and intends to use them (Section 1). It is not unowned: someone usually runs it, but that party decides alone what it does and may be careless, hostile or impossible to find. An unattended agent is the limiting case.

Appendix C: Sources

Each citation in the text names its source in parentheses and links to it; the full entries are listed here.

- D. J. Carlson, Where Control Lives in an AI System, Version 2, 16 October 2026.
- D. J. Carlson, Agent Instantiation and Control Placement, Version 2, 21 October 2026.
- Anthropic Frontier Red Team, AI models may be capable of self-replicating without access to a datacenter, 12 October 2026.
- Anthropic, Disrupting the first reported AI-orchestrated cyber espionage campaign, November 2025.
- Reuters (via KSL), AI models may soon self-replicate without access to data centers, Anthropic warns, 13 October 2026.
- OECD AI Incidents Monitor, OpenClaw AI agent exposes widespread security vulnerabilities and data leaks, 30 January 2026.
- Vercel, AI Gateway production index, July 2026.
- Open-weights LLM release history and timeline (secondary).
- European Commission AI Act Service Desk, Article 53; General-Purpose AI Code of Practice.
- Future of Privacy Forum, California's SB 53 explained.
- Cooley, New York's frontier AI law gets a California makeover, 31 March 2026.
- Executive Order 14409, Promoting Advanced Artificial Intelligence Innovation and Security, 2 June 2026.
- Paul Hastings, President Trump signs executive order challenging state AI laws, December 2025.
- Cyberspace Administration of China, NDRC and MIIT, Implementation Opinions on the Standardized Application and Innovative Development of Intelligent Agents (in Chinese), 8 May 2026.
- UK Department for Science, Innovation and Technology, Frontier AI Safety Commitments, May 2024.
- MLex, UK AI laws and security institute powers remain undecided, 14 October 2026.
- Gowling WLG, Canada launches AI for All national AI strategy, June 2026.
- RFC 2505, Anti-Spam Recommendations for SMTP MTAs, February 1999.
- Open mail relay, Wikipedia (secondary).
- The Associated Press, Open Relay Database ceases as spammers evolve, Redmond Magazine, 28 December 2006.
- dmarcian, Yahoo and Google DMARC required.
- Hogan Lovells, EU introduces comprehensive digital-era Product Liability Directive; Directive (EU) 2024/2853, text.
- Euronews, EU Commission confirms ditching of AI liability proposal, 31 July 2025.
- Withers, Authorised push payment fraud: mandatory reimbursement scheme.
- PYMNTS, Big insurance backs away from AI risk, 2026.
- 17 U.S.C. 512, Cornell Legal Information Institute.
- NIST NCCoE, Accelerating the Adoption of Software and AI Agent Identity and Authorization, concept paper, February 2026.
- Browserbase, What is Web Bot Auth (explainer; secondary source for the IETF work).
- Apple Support, Use private Wi-Fi addresses on Apple devices, 9 December 2025.
- Lookout, Securing agentic AI on mobile, 14 October 2025 (vendor blog).

- Gigazine, Liquid AI releases LFM2.5-2.6B, 5 August 2026 (reports the developer's own claims).
- Square, A guide to the liability shift.
- Worldpay, Agentic commerce liability is still being written, July 2026.
- Payments Dive, How agentic payments shift risk, October 2026 (opinion column).
- Mastercard, Verifiable Intent, 5 March 2026.
- EMVCo, Agentic payments and digital payment credentials, 10 April 2026.
- J. Scheurer, M. Balesni and M. Hobbhahn, Large Language Models can Strategically Deceive their Users when Put Under Pressure, Apollo Research, November 2023.
- D. Volkov, Badllama 3: removing safety finetuning from Llama 3 in minutes, Palisade Research, July 2024.
- UN Office of the High Commissioner for Human Rights, The right to privacy in the digital age, A/HRC/39/29, 2018 (para. 14).
- G. A. Johnson, S. K. Shriver and S. G. Goldberg, Privacy and Market Concentration: Intended and Unintended Consequences of the GDPR, Management Science 69(10), 2023.
- Financial Conduct Authority, Dear CEO letter on strong customer authentication, 20 August 2019.
- W3C, Inaccessibility of CAPTCHA: Alternatives to Visual Turing Tests on the Web, Working Group Note, 9 December 2019.
- DigiNotar, Wikipedia (secondary; reports the Fox-IT investigation).
- RFC 6962, Certificate Transparency, June 2013; Certificate Transparency, Wikipedia (secondary).
- NTIA, Dual-Use Foundation Models with Widely Available Model Weights, report, and fact sheet, 30 July 2024.
- CISA, NSA, FBI and others, IRGC-Affiliated Cyber Actors Exploit PLCs in Multiple Sectors, Including U.S. Water and Wastewater Systems Facilities, advisory AA23-335A, 1 December 2023.
- CISA, EPA, NSA, FBI and international partners, Foundations for OT Cybersecurity: Asset Inventory Guidance for Owners and Operators, 13 August 2025.
- Forvis Mazars, Regulation CC update, June 2024 (amounts effective 1 July 2025); Federal Register notice, 12 CFR 229.
- Davis Wright Tremaine, FCC Requires All Voice Providers to Implement STIR/SHAKEN or Adopt Robocall Mitigation Plans by Mid-2021, October 2020 (summary of the FCC order).
- RFC 2827 / BCP 38, Network Ingress Filtering, May 2000.
- APNIC Blog, Understanding the spoofing problem, 9 February 2018.
- Ipregistry, RPKI Covers 67% of Routes, But Four Attack Classes Slip Right Past It, July 2026 (secondary; reports Hurricane Electric's figures).
- Federal Communications Commission, FCC Proposes Closing the Non-IP Network Loophole Exploited by Robocallers to Scam Consumers, news release, 28 April 2025.
- CAIDA, Spoofer: Source Address Validation Measurement Project.
- White House Office of the National Cyber Director, Fact sheet: Roadmap to Enhancing Internet Routing Security, 3 September 2024.
- CISA, Critical Vulnerabilities in PHP Require Immediate Patching, alert, 21 October 2026.
- The Hacker News, PHP Issues Emergency Patches for Two Critical PHP2Shell RCE Flaws as Exploit Attempts Emerge, October 2026.

Appendix D: Key lists at a glance

The paper's numbered and named lists, one line each, with where each is set out in full.

D.1 Tiers of harm that must not occur (Table 1)

- T1. Catastrophic harm to humanity
- T2. Serious disruption of society's core functions
- T3. Serious injury or significant financial loss to individuals

D.2 Leverage over AI agents, by party (Table 3)

- L1. Developers of models under served access
- L2. Developers of open-weight models
- L3. Model hubs and distributors
- L4. Cloud and model hosts
- L5. Operators of critical systems
- L6. Network, telephone and device operators
- L7. Institutions: insurers, auditors, incident centers

D.3 Known gaps in the internet's plumbing (Table 4)

- Forged caller ID
- Forged return addresses
- False route announcements
- Flaws in widely shared software

D.4 Safeguards by function (Section 8)

- Bound: scale checks to what cannot be undone (8.1)
- Attribute: tie agents to someone accountable (8.2)
- Dissipate: make cheap harm at scale expensive (8.3)
- Detect: see what no single operator can (8.4)
- Contain persistence: keep agents from outliving their owners (8.5)
- Verify and bound: identity is not trust (8.6)

D.5 Listing a critical system's interfaces (Section 8.6)

1. Devices
2. Physical interfaces on each device
3. Logical interfaces within each physical one, and the software and version behind each
4. Who can use each
5. What each can change

D.6 Point-of-effect safeguards (Table A1)

- P1. Out-of-band confirmation of large irreversible actions
- P2. Delay and reversal window on high-value irreversible actions
- P3. Duplicate protection on interfaces that change things
- P4. Declared agent identity with signed requests
- P5. Rate and spend limits per identity

- P6. Revocation and reputation for agent identities
- P7. Controls on unattended agent processes
- P8. Signed checkpoints and provenance at distribution
- P9. Logs retained long enough for attribution
- P10. Incident reporting with agent indicators
- P11. Independent measurement of detection catch rates and false positives
- P12. Device defaults and network quarantine
- P13. Verified identity required for irreversible actions
- P14. Bounded authority for agents inside critical systems
- P15. Inventory of every command path

D.7 Safeguard costs and risks (Section 10)

- Identity can become surveillance (10.1)
- Compliance can entrench incumbents (10.2)
- Friction falls hardest on those with least access (10.3)
- Detection is sometimes wrong (10.4)
- The safeguards become targets (10.5)
- Controls can reach open research (10.6)

D.8 Recommendations (Section 12)

1. Legislators and standards bodies: adopt the three-tier floor, or something similar, as the scope of safeguards and standards
2. Financial and other critical-sector regulators: scale checks on irreversible actions to the stakes
3. Standards bodies: declared agent identity, and revocation of abused identities
4. Legislators and regulators: rate and spend limits and logs at public interfaces
5. Governments, or industry first: an incident center and independent measurement of detection
6. Legislators and regulators: identify long-running agent processes; provenance for open-weight checkpoints
7. Device makers and network operators: secure defaults and quarantine of recruited devices
8. Regulators of critical infrastructure: verified identity before irreversible actions
9. Regulators of critical infrastructure: bounded authority for operators' own agents
10. Regulators of critical infrastructure: an inventory of every command path
11. Legislators and courts: treat attacks on safeguards as attempts on what they protect
12. Payment regulators and standards bodies: recorded grants of authority to agents
13. Legislators and regulators: a safe harbor for operators that run the safeguards
14. Carriers and network operators: complete authentication of email, calls, traffic and routing
15. Governments and the largest users of shared software: fund maintenance and audits; patch within a set time

D.9 Open questions (Section 12)

- Q1. Protecting decision-making processes in every political system
- Q2. A state's own use of agents against its population
- Q3. Where the thresholds for repayment, delay and confirmation should sit
- Q4. Device defaults and quarantine without harming legitimate use or privacy
- Q5. How to measure whether the floor is holding